Tema 1 · Anexo 1 · Protección de Datos de Carácter Personal

SPD · Curso 2026/27 · Prof. Teodoro Rojo
Apuntes a partir de *SPD - 1A1. Protección de datos de carácter personal*. "Nota" = aclaración añadida.

Índice

1. Línea temporal: LOPD → RGPD → LOPD-GDD
2. LOPD 15/1999 (derogada)
3. RGPD (Reglamento UE 2016/679)
4. LOPD-GDD (LO 3/2018)
5. Tabla comparativa
6. Preguntas de repaso

---

1. Línea temporal

```
1995  Directiva 95/46/CE (UE) ──► cada país hace su ley
1999  LOPD · Ley Orgánica 15/1999 (España)
2007  RD 1720/2007 · Reglamento de desarrollo de la LOPD
2016  RGPD · Reglamento (UE) 2016/679 (27 abril 2016)
2018  25 mayo → RGPD de obligado cumplimiento
2018  6 dic → LOPD-GDD · LO 3/2018 (deroga la LOPD; efectos 7 dic 2018)
```

Nota: Directiva vs Reglamento: una *directiva* obliga a cada Estado a **trasponerla** con su propia ley (por eso existía la LOPD española). Un *reglamento* es **directamente aplicable y vinculante en su integridad** en toda la UE. La LOPD-GDD no sustituye al RGPD: lo **adapta y complementa** en España.

---

2. LOPD 15/1999 (derogada)

- **Ley Orgánica 15/1999, de 13 de diciembre** + su reglamento **RD 1720/2007**.
- **Objetivo (art. 1):** garantizar y proteger, en el tratamiento de datos personales, las libertades públicas y derechos fundamentales de las **personas físicas**, especialmente su **honor e intimidad personal y familiar**.
- Regula el tratamiento **independientemente del soporte** (papel o digital).
- Obliga a las empresas a implantar medidas de protección (sistemas, soportes, personal...).
- **Derogada con efectos de 7 de diciembre de 2018.**

2.1 Características

- **Dato de carácter personal:** cualquier información sobre **personas físicas identificadas o identificables**.
- Los ficheros deben reunir condiciones de **integridad y seguridad** (también locales, equipos, sistemas y programas).
- **Derechos ARCO.**
- Protección por **niveles** según la sensibilidad: **básico, medio y alto**.
- **Documento de seguridad:** recoge las medidas adoptadas; de obligado cumplimiento para quienes accedan a los ficheros.
- **Sanciones:**

Infracción	Multa
Leve	601 – 60.101 €
Grave	60.101 – 300.506 €
Muy grave	300.506 – 601.012 €

2.2 Derechos ARCO (importante)

Derecho	El afectado puede…
Acceso	Saber **si** se tratan sus datos, **para qué**, de dónde proceden y a quién se han cedido.
Rectificación	Que se **modifiquen** datos inexactos o incompletos.
Cancelación	Que se **excluyan** del tratamiento cuando ya no son necesarios, son inexactos, inadecuados, excesivos o ilegales. **Atención:** Se **bloquean, no se borran**.
Oposición	Que **cese** el tratamiento o evitar que se produzca (sobre todo con **fines comerciales**).

2.3 Niveles de seguridad (acumulativos) (importante)

Nivel	Tipos de datos	Medidas (se suman a las del nivel anterior)
Básico	Datos personales identificativos: nombre y apellidos, dirección, teléfono…	Documento de seguridad: funciones y obligaciones del personal · **registro de incidencias** · identificación y autenticación · relación actualizada de usuarios autorizados · control de acceso lógico · contraseñas: procedimiento de asignación/distribución/almacenamiento, **cambio periódico** y almacenamiento **cifrado** · gestión de soportes · **copias de respaldo al menos semanales**
Medio	Infracciones administrativas o penales · Hacienda Pública · Seguridad Social · servicios financieros · solvencia patrimonial y crédito · **evaluación de la personalidad**	+ **Responsable de seguridad** · **auditoría bienal** (cada 2 años) · **control de acceso físico**
Alto	Ideología · religión · creencias · origen racial o étnico · datos genéticos/biomédicos · **salud** · **vida sexual** · datos policiales sin consentimiento · **violencia de género** · servicios de telecomunicación	+ **Registro de accesos** (conservado **≥ 2 años**; el responsable lo revisa y hace un **informe mensual**) · medidas adicionales de copias de respaldo · **cifrado de telecomunicaciones**

La seguridad está determinada por la criticidad de los datos.

Nota: En la diapositiva pone "auditoría bianual" (dos veces al año), pero el RD 1720/2007 exige auditoría **al menos cada dos años** (= *bienal*).

---

3. RGPD

Reglamento (UE) 2016/679, de 27 de abril de 2016. **Obligatorio desde el 25 de mayo de 2018**.

- Establece un **marco común** de protección de datos en toda la UE.
- **Sustituye a la Directiva 95/46/CE**. Al ser reglamento, es **vinculante en su integridad** en toda la UE.
- **Características principales:** mayor protección · **orientación al riesgo** · **responsabilidad proactiva** · régimen sancionador **más severo**.

- **Ámbito territorial:** afecta a **todas las organizaciones que tratan datos de ciudadanos de la UE**, **aunque no tengan presencia en la UE**.

3.1 Cambio de "esquema mental" (importante)

LOPD · *Cumplimiento pasivo*	**RGPD · *Responsabilidad proactiva***
Declarar los ficheros en el Registro	Llevar un **registro interno de actividades de tratamiento**
Incluir una "cláusula LOPD"	Aplicar la **privacidad desde el diseño** (y por defecto)
"Copiar" un documento de seguridad	Seguridad basada en **gestión de riesgos**
Salir del paso, reaccionar *a posteriori*	Hacer **evaluaciones de impacto** (EIPD)
	Adoptar **códigos de conducta y certificaciones**
	Disponer de un **Delegado de Protección de Datos (DPD/DPO)**

3.2 Principios relativos al tratamiento (art. 5) (importante)

Los datos personales serán:

	Principio	**Significado**
a	**Licitud, lealtad y transparencia**	Tratados de forma lícita, leal y transparente con el interesado.
b	**Limitación de la finalidad**	Recogidos con fines **determinados, explícitos y legítimos**.
c	**Minimización de datos**	Adecuados, pertinentes y **limitados a lo necesario**.
d	**Exactitud**	Exactos y actualizados.
e	**Limitación del plazo de conservación**	No más tiempo del necesario.
f	**Integridad y confidencialidad**	Debidamente protegidos.

Nota: A estos seis se suma la **responsabilidad proactiva** (art. 5.2): el responsable debe **cumplirlos y poder demostrarlo**.

3.3 Recogida de datos y consentimiento

- Debe quedar **totalmente claro** al interesado que se recogen y tratan sus datos y en qué medida.
- **Consentimiento explícito**: declaración **inequívoca** o **acción afirmativa clara**.
- No **No valen**: casillas **premarcadas**, consentimiento **tácito** o la **inacción**.
- Hay que **informar** de riesgos, normas, salvaguardas, derechos y cómo ejercerlos.
- Los fines deben ser explícitos y legítimos y fijarse **en el momento de la recogida**.

3.4 Derechos del interesado (importante)

Se mantienen los **ARCO** y se añaden:

Nuevo derecho	**Contenido**
Supresión ("derecho al olvido")	**Amplía la cancelación**: los datos se **suprimen sin dilación indebida** si el interesado se opone y no hay obligación legal de conservarlos. Incluye **enlaces y avisos a terceros**.
Portabilidad	Recibir los datos que facilitó en un **formato estructurado** y **transmitirlos a otro responsable**.
Limitación del tratamiento (bloqueo)	Pedir que se apliquen medidas que **eviten su tratamiento futuro** (modificación, borrado...).

Nota: Nemotecnia de todos los derechos RGPD: **"ARCO-POL"** → Acceso, Rectificación, Cancelación/supresión, Oposición, **P**ortabilidad, **O**lvido, **L**imitación. (+ no ser objeto de decisiones automatizadas, ver 3.9.)

3.5 Responsabilidad proactiva (*accountability*)

- El **responsable del tratamiento** aplica medidas **técnicas y organizativas** apropiadas para **garantizar y poder demostrar** que cumple el RGPD.
- Hay que analizar **qué datos** se tratan, **con qué finalidad** y **qué operaciones** se realizan.
- **Privacidad desde el diseño y por defecto.**
- Actitud **consciente, diligente y proactiva**: medidas **preventivas** y capacidad de **demostrarlas** ante interesados y autoridades.

3.6 Orientación al riesgo e incidentes

- Las organizaciones que recogen, almacenan y gestionan datos son **responsables de su protección**.
- Medidas **proporcionales al riesgo**.
- Obligaciones: analizar el riesgo, evaluar el impacto, **monitorizar**, **documentar** los procedimientos y **notificar cualquier incidente de seguridad en 72 horas**, con toda la información necesaria.
- **Sanciones:** hasta **20 millones de €** o el **4 % del volumen de negocio global anual** (**lo que sea mayor**).

3.7 Datos sensibles (categorías especiales, art. 9.1)

Datos que, además de identificar, pueden **poner en riesgo derechos y libertades fundamentales** → protección mayor:

- Origen racial o étnico
- Opiniones políticas
- Convicciones religiosas o filosóficas
- Afiliación sindical
- Datos genéticos
- Datos biométricos (**Nota:** la diapositiva dice "biomédicos"; el art. 9.1 habla de datos **biométricos** dirigidos a identificar de forma unívoca a una persona)
- Datos relativos a la salud
- Datos relativos a la vida sexual (u orientación sexual)

3.8 Evaluación de impacto (EIPD / DPIA)

- **Obligatoria** cuando el tratamiento entrañe **alto riesgo** para derechos y libertades.
- **Alto riesgo** = categorías especiales: **personas vulnerables** (menores), **datos sensibles** (salud) o **elaboración de perfiles de comportamiento**.
- Resultado: **informe de evaluación de impacto** con los riesgos detectados y las medidas aplicadas para eliminarlos o reducirlos.

3.9 Elaboración de perfiles (*profiling*)

- Toma de **decisiones individuales** basadas en **tratamiento automatizado** para evaluar, analizar o predecir aspectos personales (rendimiento, solvencia, salud, preferencias, comportamiento…).
- Derecho a **no ser objeto de una decisión basada únicamente en medios automatizados** si produce **efectos jurídicos** o afecta significativamente (p. ej. denegar una prestación social o un **crédito online**).
- **Excepciones:** no hay otra forma de lograr el objetivo, o el interesado da su **consentimiento explícito**.

---

4. LOPD-GDD

Ley Orgánica 3/2018, de 6 de diciembre, de Protección de Datos Personales y Garantía de los Derechos Digitales.

- **Adapta** el ordenamiento español al RGPD (la LOPD había quedado obsoleta).

- Art. 1: el derecho fundamental a la protección de datos (**art. 18.4 de la Constitución**) se ejerce conforme al **RGPD y a esta ley**; además pretende garantizar los **derechos digitales** de la ciudadanía.
- **Deroga la LOPD 15/1999.**

4.1 Principales novedades (importante)

Novedad	Detalle
Registro de actividades de tratamiento	Todas las actividades quedan registradas y a disposición de las autoridades. "**Mapa de flujos de datos**". Revisión periódica.
ENS en las Administraciones Públicas	Las medidas de seguridad de datos personales en la AAPP son las **del ENS**.
Consentimiento para varias finalidades	Debe darse de forma **específica e inequívoca para cada una**.
Consentimiento de menores	Desde los **14 años**.
Consentimiento verificable	Debe poder acreditarse a requerimiento de las autoridades.
Datos de fallecidos	Los **herederos** pueden ejercer acceso, rectificación y supresión, salvo que el fallecido lo prohibiera.
Canales de denuncia interna anónimos	Para informar de conductas contrarias a la normativa.
Sistemas de información crediticia (morosos)	Deuda mínima de **50 €**; permanencia máxima **5 años**.
Más facilidades para ejercer derechos	Las entidades deben facilitar los medios y regular cómo se informa al interesado.

5. Tabla comparativa

	LOPD 15/1999	RGPD 2016/679	LOPD-GDD 3/2018
Tipo	Ley orgánica española	Reglamento UE (directamente aplicable)	Ley orgánica española (adapta el RGPD)
En vigor	1999 – dic 2018	Obligatorio desde 25/05/2018	Desde 07/12/2018
Enfoque	Cumplimiento **pasivo**, niveles básico/medio/alto	**Responsabilidad proactiva** y **riesgo**	Igual que RGPD + **derechos digitales**
Derechos	ARCO	ARCO + supresión, portabilidad, limitación, no decisiones automatizadas	Los del RGPD + fallecidos, etc.
Sanción máx.	601.012 €	20 M€ o 4 % facturación global	Remite al RGPD
Brechas	—	Notificar en **72 h**	—
Edad consentimiento	—	16 (los Estados pueden bajarla a 13)	**14** en España

6. Preguntas de repaso

1. ¿Por qué el RGPD es un *reglamento* y no una *directiva*? ¿Qué consecuencia tiene?
2. Enumera y explica los derechos ARCO. ¿Qué diferencia hay entre cancelación y supresión?
3. ¿Qué tres derechos nuevos introduce el RGPD?
4. Los seis principios del art. 5 del RGPD.
5. ¿Qué medidas añade el nivel alto de la LOPD respecto al medio? ¿Y el medio respecto al básico?

6. Clasifica según la antigua LOPD: (a) teléfono, (b) datos de solvencia, (c) datos de salud, (d) datos de violencia de género. *Solución:* (a) básico · (b) medio · (c) alto · (d) alto
7. ¿Es válido un formulario con la casilla "acepto recibir publicidad" ya marcada? ¿Por qué?
8. ¿Cuándo es obligatoria una evaluación de impacto?
9. Plazo de notificación de una brecha y sanción máxima en el RGPD.
10. Edad mínima de consentimiento en España. Condiciones del fichero de morosos.
11. ¿Qué significa "responsabilidad proactiva"? Compárala con el "cumplimiento pasivo".

Recursos

- AEPD · El Reglamento General de Protección de Datos — aepd.es/reglamento
- AEPD · Guía del RGPD para responsables de tratamiento
- AEPD · Resoluciones y sanciones (útil para ver casos reales)